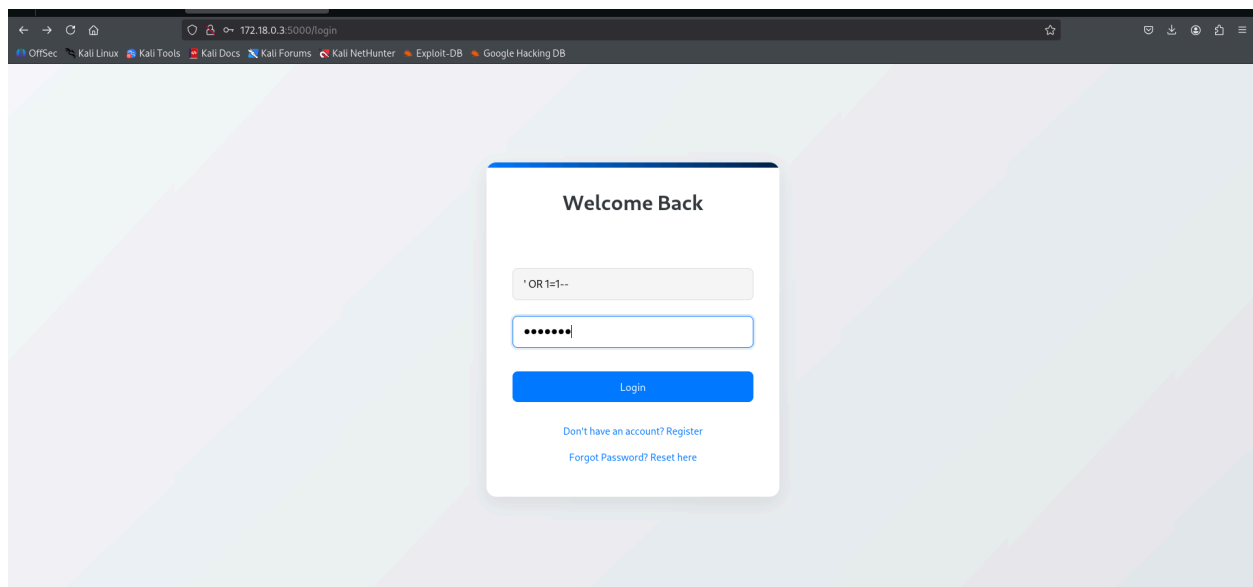


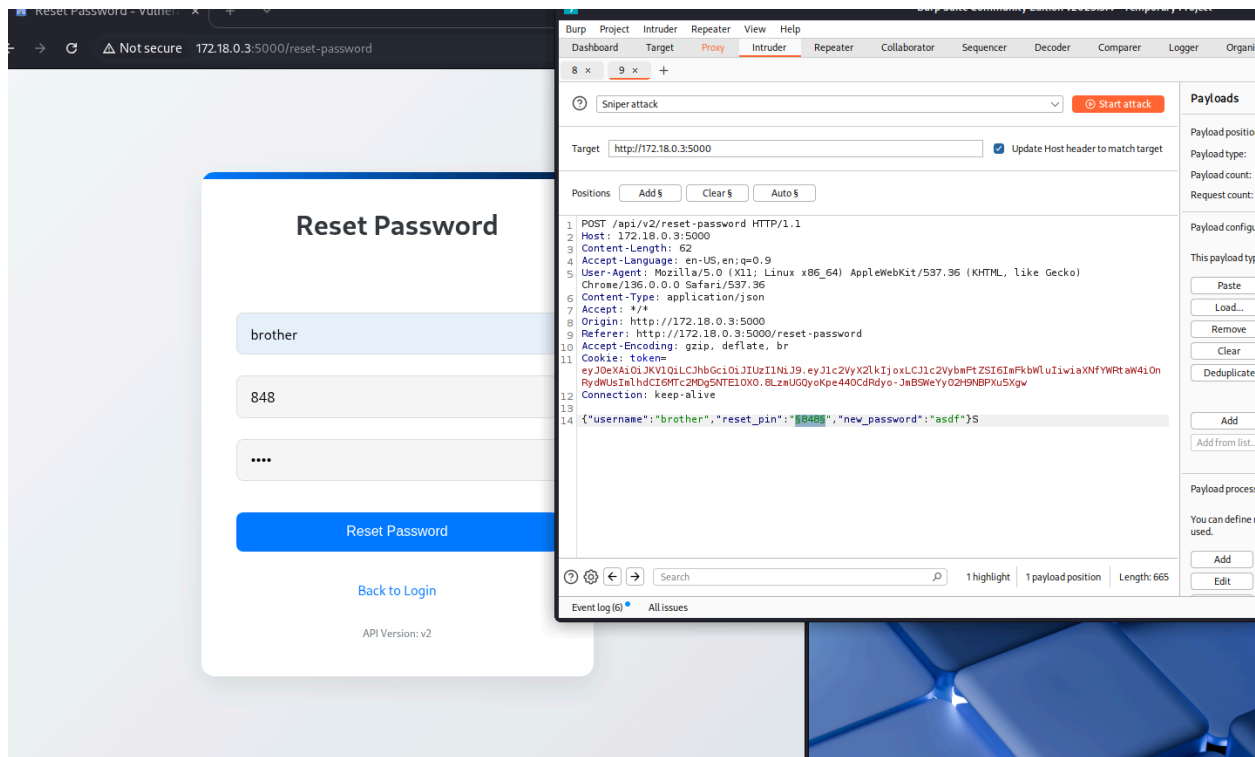
Vulnerability Analysis Report

Source: vuln-bank (<https://github.com/Commando-X/vuln-bank>)

1. **Lack of Rate Limiting on Password Attempts:** This vulnerability allows an attacker to perform an unlimited number of password guesses in a short period, making the system susceptible to brute-force attacks. This can lead to unauthorized access if a weak password is used or if the attacker has a pre-computed list of common passwords.
2. **SQL Injection:** This vulnerability allows an attacker to bypass authentication by injecting malicious SQL code into the username and/or password fields. By entering ' OR 1=1-- into the username field (and any password), the attacker can gain unauthorized access to the admin account. This bypasses the intended authentication mechanism, potentially exposing sensitive data and allowing for full system compromise.



3. **OTP Brute-Forcing:** This vulnerability allows an attacker to bypass the password reset mechanism by brute-forcing a 3-digit One-Time Password (OTP). By intercepting the password reset request packet and repeatedly guessing the 3-digit OTP, an attacker can gain unauthorized access to a user's account. The limited length of the OTP (3 digits) makes it highly susceptible to this type of attack, as there are only 1000 possible combinations (000-999). This can lead to account compromise and unauthorized access to sensitive information.



4. Insufficient Authorization (Privilege Escalation): This vulnerability arises from the fact that an administrative account has the ability to modify the balance of any user. If an attacker gains access to this administrative account, they can manipulate user balances, leading to financial fraud or disruption of service. This represents a significant risk as it can compromise the integrity of financial data and user trust.

5. Negative Balance Exploitation: This vulnerability is related to the "Insufficient Authorization (Privilege Escalation)" vulnerability. Specifically, when an administrative account attempts to modify a user's balance, it's possible to input a negative number. This action, instead of reducing the balance, can result in the user's account being credited with money, effectively generating funds from a negative input. This can lead to financial fraud, unauthorized fund generation, and severe disruption of financial data integrity within the system.